

LAB 01: OLAY MÜDAHALESİ VE DİJİTAL ADLİ BİLİŞİM

Teknik Olay Müdahale Raporu · GitHub Portföy Sürümü

Rapor ID	IR-2026-LAB01
Hedef Sistem	AWS EC2 Instance — Ubuntu 22.04 LTS — ip-172-31-42-76
Kritiklik Seviyesi	Yüksek / Kritik (High / Critical)
Analist / Rol	Junior SOC Analyst / DFIR Responder
Durum	Temizlendi / Kapatıldı (Remediated / Closed)
Tarih	6 Ağustos 2026

1. Yönetici Özeti

Hedef AWS EC2 sunucusu üzerinde şüpheli süreçler ve anormallikler tespit edilmesi üzerine kapsamlı bir Olay Müdahalesi (Incident Response) ve Dijital Adli Bilişim (DFIR) süreci yürütülmüştür.

İnceleme sonucunda saldırganın 198.51.100.45 IP adresinden SSH kaba kuvvet yöntemiyle `app_deployer` kullanıcısının parolasını ele geçirdiği belirlenmiştir. Saldırgan root yetkisine yükselmiş, `/tmp/.sys_update` üzerinden TCP 4444 portunda dinleyen Python tabanlı bir bind shell çalıştırmış; kalıcılık için SUID arka kapısı, kötü amaçlı cron görevi ve yetkisiz SSH anahtarı eklemiştir. Ayrıca `/etc/passwd` ve `/etc/shadow` dosyalarını dışarı sızdırmaya hazırlamak üzere arşivlemiştir.

Sonuç: Tüm tehdit bileşenleri izole edilmiş ve silinmiştir. Güvenliği zayıflayan kullanıcı hesabı kilitlenmış, müdahale sonrası doğrulama ile tespit edilen kalıntıların ortadan kaldırıldığı doğrulanmıştır.

2. MITRE ATT&CK® Haritalaması

Taktik	Teknik	ID	Kanıt
Initial Access	Valid Accounts / SSH	T1078	198.51.100.45 üzerinden <code>app_deployer</code> parolasıyla erişim
Privilege Escalation	Setuid / Setgid	T1548.001	<code>/var/tmp/.systemd-helper</code> , SUID root (4755)
Persistence	Scheduled Task: Cron	T1053.003	<code>/etc/cron.d/systemd-check</code>
Persistence	Account Credentials: SSH Keys	T1098.004	<code>authorized_keys</code> içine saldırgan anahtarı
Defense Evasion	Masquerading / Hidden Files	T1036	Gizli isimli <code>/tmp/.sys_update</code>

Command & Control	Non-Standard Port	T1571	TCP 4444 üzerinde dinleyici
Collection / Exfiltration	Archive Collected Data	T1560	/var/tmp/.sys_config_bak.tar.gz

3. İnceleme Ortamı ve Kaynakları

- **İşletim sistemi:** Ubuntu Linux, AWS EC2
- **Log kaynakları:** /var/log/auth.log, journalctl / sshd
- **Ağ ve süreç araçları:** netstat, ps, /proc
- **Dosya sistemi araçları:** find, ls, cat

4. Adli İnceleme ve Bulgular

4.1 Ağ ve Port Triage

```
sudo netstat -tulpn

tcp  0  0  0.0.0.0:4444  0.0.0.0:*  LISTEN  3723/.sys_update
tcp  0  0  127.0.0.53:53  0.0.0.0:*  LISTEN  349/systemd-resolve
tcp  0  0  0.0.0.0:22    0.0.0.0:*  LISTEN  1/init
```

Bulgu: PID 3723 ile ilişkili, gizli isimli .sys_update süreci TCP/4444 üzerinde 0.0.0.0 adresine bağlıydı. Bu, servisin tüm ağ arayüzlerinden erişilebilir olduğunu gösterir.

4.2 Süreç ve İkili Dosya Analizi

```
ps aux | grep 3723
sudo ls -l /proc/3723/exe

root 3723 ... /tmp/.sys_update -c import socket,time; s=socket.socket(); s.bind(('0.0.0.0', 4444)); s.listen(5); ...
lrwxrwxrwx ... /proc/3723/exe -> /tmp/.sys_update
```

Bulgu: Süreç root yetkisiyle çalışmaktaydı. Python ikilisi gizli dosya adıyla /tmp altında konumlandırılmış ve Python socket modülüyle ağ dinleyicisi başlatılmıştı.

4.3 İlk Erişimin Doğrulanması

```
sudo journalctl -t sshd -n 20

Aug 06 06:36:18 ... Failed password for invalid user admin from 198.51.100.45 ...
Aug 06 06:36:18 ... Failed password for app_deployer from 198.51.100.45 ...
Aug 06 06:36:18 ... Accepted password for app_deployer from 198.51.100.45 ...
```

Bulgu: Başarılı parola tabanlı SSH erişimi, aynı saniyede görülen başarısız denemeleri takip etmiştir. Şüpheli sürecin başlangıç zamanı da bu zamanla eşleşmektedir.

4.4 Kalıcılık, Yetki Yükseltme ve Veri Hazırlama

```
sudo find /tmp /var/tmp -type f -perm -4000 -ls
sudo cat /home/app_deployer/.ssh/authorized_keys
sudo cat /etc/cron.d/systemd-check
sudo ls -la /var/tmp
```

Bileşen	Kanıt	Analiz
SUID backdoor	/var/tmp/.systemd-helper -rwsr-xr-x, root	SUID biti, dosyayı çalıştıran düşük yetkili kullanıcının etkin yetkisini dosya sahibine (root) yükseltebilir.
SSH key backdoor	/home/app_deployer/.ssh/ authorized_keys attacker@evil-c2.com	Parola değişse bile anahtar tabanlı erişim sağlayabilecek kalıcılık mekanizması.
Cron kalıcılığı	* * * * * root /var/tmp/.sys_update >/dev/null 2>&1	Kötü amaçlı bileşenin her dakika root olarak yeniden çalıştırılması hedeflenmiş.
Veri arşivleme	/var/tmp/.sys_config_bak.tar.gz	/etc/passwd ve /etc/shadow içeriğinin dışarı sızdırma öncesi hazırlanması.

5. Müdahale ve Temizlik

Olay müdahalesi ilkesi: Temizlikten önce, mümkünse kanıtlar korunmalı ve kurumun olay müdahale prosedürüne uygun onay alınmalıdır. Bu laboratuvar senaryosunda süreç doğrudan durdurulmuş ve kalıntılar kaldırılmıştır.

```
# 1. Aktif C2 / zararlı sürecin sonlandırılması
sudo kill -9 3723

# 2. Kalıcılık mekanizmalarının kaldırılması
sudo rm -f /etc/cron.d/systemd-check
sudo rm -f /home/app_deployer/.ssh/authorized_keys

# 3. Zararlı dosyalar ve veri paketinin kaldırılması
sudo rm -f /tmp/.sys_update
sudo rm -f /var/tmp/.systemd-helper
sudo rm -f /var/tmp/.sys_config_bak.tar.gz

# 4. Etkilenen hesabın kilitlenmesi
sudo passwd -l app_deployer
```

6. Müdahale Sonrası Doğrulama

```
sudo netstat -tulpn | grep 4444
# Çıktı yok: TCP/4444 dinleyicisi kapalı

sudo ls -la /tmp/.sys_update /var/tmp/.systemd-helper /etc/cron.d/systemd-check 2>&1
# No such file or directory: kalıntılar bulunamadı
```

Doğrulama Sonucu: TCP/4444 dinleyicisi kapalıdır; incelenen zararlı süreç, dosyalar ve cron girdisi artık mevcut değildir.

7. Güvenlik Sıkılaştırma Önerileri

- SSH parola doğrulamasını kapat:** `sshd_config` içinde `PasswordAuthentication no` kullan; yalnızca yönetilen SSH anahtarlarına izin ver.
- Fail2Ban etkinleştir:** Tekrarlanan başarısız SSH denemelerini algılayıp geçici ağ engeli uygula.
- Geçici dizinleri sıkılaştır:** Uygun mimaride `/tmp` ve `/var/tmp` için `noexec` ve `nosuid` mount seçeneklerini değerlendir ve uygulama uyumluluğunu test et.
- En az yetki:** `app_deployer` gibi dağıtım/servis hesaplarının `sudo` yetkilerini sınırla; hesap, parola ve SSH anahtarı yaşam döngüsünü düzenli olarak gözden geçir.
- Görünürlük:** SSH, `sudo`, kullanıcı/grup ve kritik dosya değişikliklerini merkezi olarak topla; anlamlı uyarılar tanımla.

Bu doküman, kontrollü bir eğitim laboratuvarında üretilmiş teknik olay müdahale raporudur. Üretim ortamı için prosedürler; kanıt koruma, kapsam belirleme, yetkilendirme, iletişim ve iyileştirme süreçleriyle genişletilmelidir.